

Nombre: Luis Alberto Vargas Gonzalez

Fecha: 19/01/2026

Actividad y unidad: U1 A1: Práctica: Etapas de análisis de seguridad.

Clase: Seguridad de Software.

Maestría en Ciberseguridad.

INTRODUCCIÓN.

En este documento se detallarán las fases, etapas y políticas prácticas de la seguridad del software en un entorno educativo de carácter privado (llamado SuBiré Business School).

En donde dicha institución cuenta con educación básica conformada por Primaria y Secundaria, así como con educación Bachillerato y preuniversitaria, en los cuales es totalmente aplicable las etapas de análisis de seguridad junto con las políticas prácticas que le darán a la institución la credibilidad y confianza que necesita tener por parte de los alumnos, docentes y sobre todo padres de familia, siendo estos últimos los que sostienen económicamente a la institución.

Parte 1: Identificación y explicación de las etapas.

1. Clasificación de la información: Consiste en inventariar y etiquetar los activos de información de la organización según su nivel de sensibilidad, valor y criticidad. No toda la información requiere la misma protección; por ejemplo, calificaciones, datos médicos de los alumnos, información financiera de padres de familia (confidencial) requieren más seguridad que el menú de la cafetería, o los datos de la oferta educativa en su sitio web (público).

2. Fragmentación de la información: Se refiere a la estrategia de "no poner todos los huevos en la misma canasta". Implica dividir la información y los sistemas en segmentos aislados. Si un atacante compromete un servidor (ej. el web server de la página pública), la fragmentación impide que salte lateralmente a la base de datos de pagos o expedientes académicos.

3. Cambio de códigos y claves: Es la gestión del ciclo de vida de las credenciales y el cifrado. Consiste en establecer periodos de vigencia para contraseñas de usuarios y, más importante aún, rotar las claves criptográficas (las llaves que descifran las bases de datos o aseguran las conexiones VPN) para evitar que, si una llave antigua fue comprometida, se siga teniendo acceso.

Parte 2: Identificación del Proyecto (Basado en tu escenario)

Nombre del Proyecto: Implementación de un Programa de Seguridad de la Información en el Colegio SuBiré Business School.

Contexto: Se trata de una institución educativa privada que abarca niveles de **Primaria, Secundaria y Bachillerato**. La escuela maneja un volumen alto de datos sensibles de menores de edad, información financiera de los padres de familia y registros académicos.

Rol: Administrador de Sistemas.

Justificación de la aplicabilidad: Este entorno es crítico para aplicar las políticas prácticas porque:

1. **Datos Sensibles:** Se manejan datos personales de menores (PII), lo cual tiene implicaciones legales fuertes en la Ley Federal de Protección de Datos Personales en Posesión de Particulares (LFPDPP).
2. **Riesgo Financiero:** Se procesan pagos de colegiaturas y gastos en general de alumnos como compra de útiles, uniformes y refrigerios en recesos.
3. **Factor Humano:** Existe una alta rotación de alumnos y una plantilla de profesores que a menudo comparten contraseñas o equipos, creando brechas de seguridad que las políticas deben cerrar.

Parte 3: Desarrollo de las 6 políticas prácticas

1. Analizar y clasificar los datos según su sensibilidad

Aplicación: Se establecerá un esquema de etiquetado de datos en tres niveles dentro de los servidores del colegio:

- **Público:** Información general en la web (oferta académica, calendario escolar).
- **Interno:** Material didáctico de profesores, circulares internas.
- **Confidencial:** Expedientes psicológicos de alumnos, datos bancarios de padres, nómina de maestros, administrativos, TI, personal de seguridad y de mantenimiento.
- *Acción:* Se configurarán permisos en el servidor de archivos (File Server) basados en estas etiquetas.

2. Dar acceso a datos sensibles solo al personal imprescindible

Aplicación (Principio de Mínimo Privilegio):

- Los docentes solo tendrán acceso a las calificaciones y datos de *sus* grupos asignados, no a toda la escuela.
- El personal administrativo (caja) tendrá acceso a los módulos de cobranza, pero no a los expedientes médicos o psicológicos de los alumnos.
- *Acción:* Auditoría de usuarios en el Active Directory para eliminar permisos heredados innecesarios.

3. Seleccionar al personal adecuadamente

Aplicación:

- Dado que el personal interactúa con menores y sistemas críticos, se implementará una política de verificación de antecedentes (no penales) para cualquier nuevo empleado con acceso a la red administrativa.
- Se incluirá una cláusula de confidencialidad (NDA) obligatoria en los contratos de los maestros respecto a los datos de los alumnos.

4. Depurar / eliminar todos los datos (Retención de datos)

Aplicación:

- Se establece una política de "Purga Digital". Los expedientes de alumnos que se graduaron hace más de 5 años (o el tiempo que marque la ley de educación local) serán eliminados de los servidores activos y pasados a un almacenamiento en frío (Cold Storage) o destruidos si ya no es legal retenerlos.
- Se eliminarán automáticamente las cuentas de correo institucional de exalumnos y exprofesores 30 días después de su baja.

5. Establecer mecanismos de doble autenticación (MFA)

Aplicación:

- Será **obligatorio** el uso de autenticación de dos factores (2FA) para el acceso al sistema de gestión escolar ("Saeko", "Control Escolar", etc.) y al correo electrónico del personal administrativo y directivo.
- Esto mitiga el riesgo de *phishing*, muy común en escuelas donde los maestros pueden abrir correos maliciosos inadvertidamente.

6. Cambiar las claves con frecuencia

Aplicación:

- **Usuarios:** Se forzará mediante política de grupo (GPO) el cambio de contraseña cada 90 días para administrativos y cada semestre para docentes.
- **Infraestructura:** La contraseña del Wi-Fi de la sala de maestros y administrativa se cambiará bimestralmente. Las claves de acceso *root* a los servidores y firewalls se rotarán cada vez que un miembro del equipo de TI deje la institución.

CONCLUSIÓN.

Como se analizó en esta actividad, la **clasificación, fragmentación y gestión de claves** constituyen los pilares fundamentales para iniciar cualquier programa de seguridad de la información. La versatilidad de estas fases permite que sean aplicables y adaptables a distintos sectores, independientemente de su giro.

Es crucial recalcar que la implementación rigurosa de estas seis políticas prácticas trasciende la protección de datos; garantiza la **continuidad operativa y tecnológica** de la institución educativa. Además, fortalece la **reputación y la confianza** ante la comunidad escolar, convirtiéndose en un diferenciador estratégico en un sector altamente competitivo, donde las instituciones privadas deben ofrecer garantías superiores frente a la amplia oferta pública y privada existente.